

Data Retention and Disposal Policy

Lumière Ledger — Financial Management Platform

Document Version:	1.0
Effective Date:	May 18, 2026
Review Cycle:	Annual (or upon material change in data practices)
Classification:	Confidential — Compliance Use
Owner:	Joshua Deuermeyer, Owner & Developer
Contact:	joshua.deuermeyer@gmail.com
Related Policies:	Information Security Policy v2.0, Access Controls Policy v1.0

Confidential — restricted to authorized personnel and compliance reviewers.

1. Purpose and Scope

This Data Retention and Disposal Policy establishes the rules governing how Through The Lens Media (TTLM) retains, archives, and securely disposes of data collected and processed by the Lumière Ledger financial management platform. It applies to all user data, financial records, system logs, and data received from third-party integrations including the Plaid banking API.

This policy is designed to comply with applicable data privacy regulations, minimize data exposure risk, and ensure users retain control over their personal and financial information throughout its lifecycle.

2. Data Categories and Retention Periods

The following table defines retention periods for each category of data processed by Lumière Ledger. Retention periods begin from the date of last account activity unless otherwise specified.

Data Category	Examples	Retention Period	Legal Basis
User Account Data	Email, name, business profile, Settings	Duration of active account + 90 days post-termination	Contract performance; user consent
Financial Transactions	Expenses, income, categories, Durations of active account + 7 years post-termination	Duration of active account + 7 years post-termination	IRS recordkeeping requirements (26 USC § 6001)
Receipt Files	PDF/image attachments stored on S3	Duration of active account + 7 years post-termination	IRS recordkeeping requirements

Invoice Records	Invoice PDFs, line items, payment status, etc.	Duration of active account + 7 years post-deletion	IRS record-keeping, contract records
Plaid Access Tokens	Encrypted OAuth tokens for bank account access	Indefinite (until user revokes access or 11 months access expires)	Minimize access, then immediate deletion
Bank Transaction Data	Account metadata, balances, transactions	Duration of active account + 90 days post-deletion	Plaid 90-day post-deletion necessary
CRM / Lead Records	Lead names, contact info, project details	Duration of active account + 2 years post-deletion	Legitimate business interest
System / API Logs	Request logs, error logs, authentication events	90 days from creation — then Security Incident Response	Security incident response
Gemini AI Queries	User-submitted financial questions (processed & stored)	Indefinite (processed & stored)	Minimize necessary principle
Backups	Point-in-time database snapshots (Supabase PITR)	Indefinite (Supabase PITR)	Disaster recovery by Supabase

IRS 7-Year Rule: Financial records (transactions, receipts, invoices) are retained for seven years post-account-deletion because IRS guidance recommends retaining business records for at least 7 years to support audit and amended return requirements. Users may request earlier deletion in writing; TTLM will honor such requests where no legal hold applies.

3. User Data Deletion Rights

Users retain the right to request deletion of their personal data at any time. TTLM honors deletion requests in compliance with applicable privacy law, subject to legal retention obligations.

How Users Request Deletion

- Self-service: Users may export a full data archive from the Infrastructure tab (Master Business Archive — JSON) and then contact support to request account deletion
- Email request: Send a deletion request to joshua.deuermeyer@gmail.com from the registered account email address
- Response time: Deletion requests are acknowledged within 5 business days and completed within 30 days

What Gets Deleted Immediately

- Supabase Auth account (user_id, email, password hash, sessions)
- All database rows tied to the user_id across all tables (expenses, invoices, assets, leads, settings, rules, equipment, mileage)
- All receipt and file attachments in Supabase Storage
- All Plaid access tokens — triggering immediate Plaid item deletion via API
- All user_roles entries

What Is Retained Post-Deletion (and Why)

Retained Data	Retention Period	Reason
Financial transaction records, invoices, receipts	7 years	IRS record-keeping compliance — may be required for audits or amended returns
System logs referencing the user's activity	90 days from creation	Security incident investigation and fraud prevention
Anonymized aggregate analytics	Indefinite (no PII)	Platform improvement — no personally identifiable data retained

4. Data Disposal Procedures

Data disposal is the secure, permanent destruction of data that has reached the end of its retention period or has been requested for deletion. TTLM relies on the disposal mechanisms provided by its SOC 2-certified infrastructure partners.

Database Records (Supabase PostgreSQL)

- Hard deletes are issued via SQL DELETE statements — no soft-delete pattern is used for user-requested account deletions
- Supabase's underlying storage provider (AWS) performs cryptographic erasure on deleted data blocks — data cannot be recovered from storage media
- Row-Level Security ensures deleted data is immediately inaccessible to all other users

File Storage (Supabase Storage — Receipts)

- Files are deleted from Supabase Storage via the Storage API on account deletion
- Supabase Storage uses AWS S3-compatible infrastructure — deleted objects are cryptographically erased
- Signed URLs for deleted files return 404 immediately after deletion

Plaid Tokens

- On account deletion or user-initiated bank disconnection, TTLM calls the Plaid /item/remove endpoint — this revokes the access token at Plaid's API level
- The encrypted token record is then hard-deleted from the database
- Plaid retains transaction data per their own retention policy; TTLM cannot delete data held by Plaid on their platform

Backups

- Supabase point-in-time recovery (PITR) snapshots are retained for 30 days on a rolling basis — older snapshots are automatically overwritten
- TTLM does not maintain separate manual database backups that would require independent disposal procedures

Development Environment

- No production data is stored on local development machines — all data resides in cloud infrastructure
- Local .env files containing credentials are deleted when no longer needed and are never committed to version control

5. Legal Hold Procedures

In the event of a legal hold (litigation, regulatory investigation, or law enforcement request), normal retention schedules may be suspended for the affected data. The following procedures apply:

- Upon receipt of a valid legal hold notice, Joshua Deuermeyer will immediately flag the affected user accounts and data scope
- Automated deletion processes for flagged data will be suspended for the duration of the hold
- Legal hold notices will be reviewed by legal counsel prior to compliance
- Users subject to a legal hold will be notified to the extent permitted by law
- Once the hold is lifted, the standard retention schedule resumes and deletion occurs within 30 days

6. Policy Review and Compliance

This policy is reviewed annually or upon any of the following triggering events: a change in applicable data privacy law, a new data category introduced by a product change, a security incident involving retained data, or activation of the Plaid banking integration.

Compliance Monitoring

- Annual review of retention periods against current IRS guidance and applicable state privacy laws
- Quarterly audit of log retention — verify logs older than 90 days are purged
- Annual confirmation that Supabase PITR window remains at 30 days or less
- Upon any user deletion request — verify all in-scope data is removed within 30 days and document the outcome

Policy Attestation

I, Joshua Deuermeyer, as the sole owner and operator of Through The Lens Media, attest that this Data Retention and Disposal Policy is implemented, enforced, and reviewed on the schedule described herein.

Joshua Deuermeyer

Owner & Developer, Through The Lens Media

Date